

Scoped Mitigation of Application-Layer DDoS with a Session-Centric Knowledge Graph

Natanael Oliveira, Arthur Kobielski, Marcos Luna, Luigi Carro, Jéferson Campos Nobre, and Eder John Scheid
Institute of Informatics, Universidade Federal do Rio Grande do Sul (UFRGS), Porto Alegre, Brazil
{natanael.oliveira, arthur.kobielski, marcos.luna, carro, jcnobre, ejscheid}@inf.ufrgs.br

Abstract—Distributed Slow HTTP DoS keeps every source below any per-source threshold. Flagging the attacked endpoint takes little more than an origin count; the hard decision is which clients to block without blocking the service’s own users, and the natural answer is harmful. We model the HTTP session as a first-class entity of an OWL knowledge graph, linked to other sessions by six sub-properties weighted by evasion cost; one SPARQL/SWRL rule derives verdict, evidence and scope. On generated stealthy campaigns, per-session detection stays at chance while cross-session features reach ROC AUC 0.93–0.98. Scoping by the cluster’s most common TLS fingerprint blocks 0% of a botnet spread over several stacks and 39% of legitimate traffic; a binomial enrichment test against normal traffic blocks 90% with no collateral observed and no label, matching a learned model given the profile and the campaign’s labels. On eight days of CDN traffic the test names botnet stacks real clients also present, which a filter of unseen fingerprints cannot, and fires on 4% of flash crowds against 65% for a z -score. Joined with that filter behind a distinct-origin trigger, it stops 38–78% of 100 to 1 000 injected attackers per window (20–62% on shared stacks) and fires on 0.1% of clean windows, where it blocks a median 30% of clients. The graph earns its place: its compiled count query matches a production day’s export window for window, a new signal costs four triples and no code, and the STIX 2.1 export passes the OASIS validator in strict mode.

Index Terms—security management, knowledge graph, application-layer DDoS, semantic models, automated reasoning, explainability, mitigation policy

I. INTRODUCTION

Application-layer Distributed Denial of Service (DDoS) attacks continue to grow in volume and frequency. In August 2023, HTTP/2 Rapid Reset (CVE-2023-44487) pushed mitigation peaks to 398 million requests per second from roughly twenty thousand machines [1], [2], and Cloudflare blocked more than 6500 hyper-volumetric attacks in Q2 2025 alone [3]. Volumetric defenses are built to absorb attacks of this magnitude, and detection is harder at the low-rate end of the spectrum, where *distributed Slow HTTP DoS* sits: Slowloris and its descendants, plus rate-based variants that still hold connections open, such as HULK and GoldenEye [4], exhaust a server from several coordinated origins, each sending requests small enough that no per-source threshold is crossed.

A stealthy campaign also shapes each session to look legitimate on the per-session signals detectors rely on, such as connection duration and route entropy [5]. What remains discriminative lives in the structure *between* sessions: the same client fingerprint recurring across many origins, and those origins converging on one endpoint. Framed this way, the

problem belongs to network and service management as much as to detection, because acting on it requires a decision: *which* clients to act on, on *what* evidence, and with a filter narrow enough to spare the legitimate users of the attacked service.

Existing work addresses the detection side of this problem and leaves the operational side open. A meta-analysis of 75 studies finds that 47% of application-layer DDoS detectors derive their features from HTTP sessions [6], flattened into a numeric vector before the classifier, which then cannot reason about fingerprints recurring across origins or about patterns that exist only between individually normal sessions. Graph-based detectors keep such relations: KLAGe [7] builds knowledge graphs from network logs, classifies nodes with Graph-BERT [8] and reports in natural language, reaching $F_1 = 84.1\%$ on IoT benchmarks with DDoS Slowloris. Three opportunities remain open. First, the reasoning unit is the *network node* (port, IP, flow), while Layer-7 coordination becomes visible only at the level of the application session. Second, coordination is captured implicitly, in learned embeddings, so no operator can inspect the relations behind the verdict. Third, the output stops at a report, whereas acting on it demands a mitigation policy whose scope follows from the graph. These three gaps define the space this paper occupies.

This paper addresses them with a knowledge-graph solution that scopes the mitigation of application-layer DDoS. It resolves each HTTP/TLS request to an `ApplicationSession` node of an OWL graph kept over a sliding window, links the sessions by sub-properties weighted by the attacker’s cost of breaking each signal, and fires a SPARQL/SWRL rule whose derivation is the verdict and whose discriminator scopes the mitigation. We target campaigns run from botnets of compromised devices, whose TLS stacks their operator cannot cheaply replace, and evaluate bots that present a browser’s fingerprint as the boundary of the method. This paper makes four contributions. (i) We propose an OWL ontology in which the HTTP session is a first-class entity, related to other sessions by *six typed sub-properties* weighted by evasion cost, so that network proximity, which modern botnets break trivially, enters only as auxiliary evidence. (ii) We define a decision procedure in which a SPARQL/SWRL rule fires on the weighted coordination mass $\Omega(S)$ of a candidate cluster, so that the reported verdict is the derivation that satisfied the rule, and show that at window scale this mass acts as a volume trigger, which a count of distinct origins gates at least as well, with half the false alarms on production traffic. (iii) We

TABLE I
COMPARISON OF RELATED WORK

Work	Year	Objective	Reasoning Unit	Cross-session Relation	Verdict Explanation	Mitigation Scope	Collateral
[9]	2012	L7 DDoS	Session as Vector	-	-	-	-
[10]	2015	Flow Anomalies	Flow Statistics	-	-	-	-
[5]	2023	L7 DoS	Session as Vector	-	-	-	-
[11]	2024	Device Dependencies	Network Device	Implicit (Learned)	-	-	-
[12]	2024	IT Intrusion	Host	Implicit (Learned)	-	-	-
[13]	2024	Bot Traffic	JA4 Fingerprint	Proprietary	-	Undisclosed	Undisclosed
[7]	2026	Network Threats	Network Node	Implicit (Learned)	Post-hoc (LIME/LLM)	-	-
This Work	2026	Distributed L7 DDoS	Application Session	Explicit (Typed and Weighted)	Derivation	Derived	Reported

derive the mitigation scope from the same graph and export it with its evidence chain in JSON-LD and STIX 2.1. We show that the natural choice, the property most of the cluster shares, is harmful under realistic conditions, and replace it with a binomial enrichment test over a profile of normal traffic, counted in origins at a calibrated level, which on production traffic names botnet stacks shared with real clients and rarely fires on flash crowds. (iv) We evaluate the approach against a strong per-session baseline and a learned model given the same profile as the campaign grows more distributed, and on eight days of production traffic, and measure the false-positive rate of the resulting mitigation filter as collateral damage on legitimate traffic.

Section II reviews related work, Section III presents the framework and Section IV the evaluation methodology. Section V reports the results, Section VI discusses operational placement and limitations, and Section VII concludes.

II. RELATED WORK

Table I compares this work with prior art on four dimensions: the reasoning unit, the representation of relations between sessions, the form of the explanation, and whether a mitigation scope and its collateral cost follow from that representation. The subsections cover security knowledge graphs, Layer-7 detection, and how both treat sessions.

A. Knowledge Graphs for Security and Management

The first wave of security knowledge graphs was *static*: entities extracted from Common Vulnerabilities and Exposures (CVE), reports and blogs, normalized and linked into a queryable base [14], [15]. In the words of a survey of the area [16], the resulting gap is that “*it is still unclear how to implement the knowledge graph to face real industrial difficulties in cyber attack and defense situations*”. Graphs built from threat intelligence text do not capture runtime traffic structure.

More recent work populates graphs from the traffic itself, and KLAG [7] is the closest of these to the approach proposed here. Graph representations are also gaining ground in adjacent management tasks: one line identifies device dependencies through link prediction over network graphs [11], another learns attack action sequences from testbed measurements [12]. Both operate on network-level entities, and neither derives a mitigation scope from what it finds.

B. Layer-7 HTTP DDoS Detection

The state of the art on Layer-7 HTTP DDoS detection [4], [17] falls into two categories: (i) statistical profiling and (ii) Machine Learning (ML). The first applies Principal Component Analysis (PCA) either to flow statistics [10] or to a per-session behavioral matrix [9], the latter being among the first formulations to put the session at the center, though still as a feature vector. The second and more recent category applies supervised learning over session features [5], whose authors note that the method was not validated in real time and that its output is binary, with no ontological explanation. Neither category retains a relation between sessions: whatever coordination exists is dissolved into the feature vector before the classifier ever sees it.

C. Session Modeling in Anomaly Detection

Among the 75 studies of a meta-analysis on the topic [6], none keeps the session as an object with identity, target, behavior and typed relations. The reduction is uniform, and it puts cross-session reasoning beyond the detector’s reach.

Industrial bot-management platforms do exploit cross-session structure: signals aggregated per JA4 over recent traffic feed bot scoring and DDoS protection [13]. They are proprietary, with no public ontology, no reproducible academic benchmark and no formalized collateral-damage metric.

Table I makes the boundary explicit. Statistical and machine-learning detectors reduce the session to a vector, so no relation between sessions survives and no mitigation scope or cost can follow from the decision. Graph-based detectors keep relations, on network-level entities and in learned form, and industrial platforms act on per-fingerprint aggregates without disclosing the representation or the cost of acting on it. No published approach, therefore, holds three properties together: the application session as the reasoning unit, explicit and typed relations between sessions, and a mitigation scope derived from the representation that produced the verdict, with its collateral damage reported. The rest of this paper supplies that combination and measures what it costs when the scope is wrong.

III. SESSION-CENTRIC KNOWLEDGE GRAPH

Fig. 1 summarizes the framework. Four stages run over live traffic: HTTP events are ingested, lifted into ontology instances with sessions as persistent graph nodes, evaluated by semantic

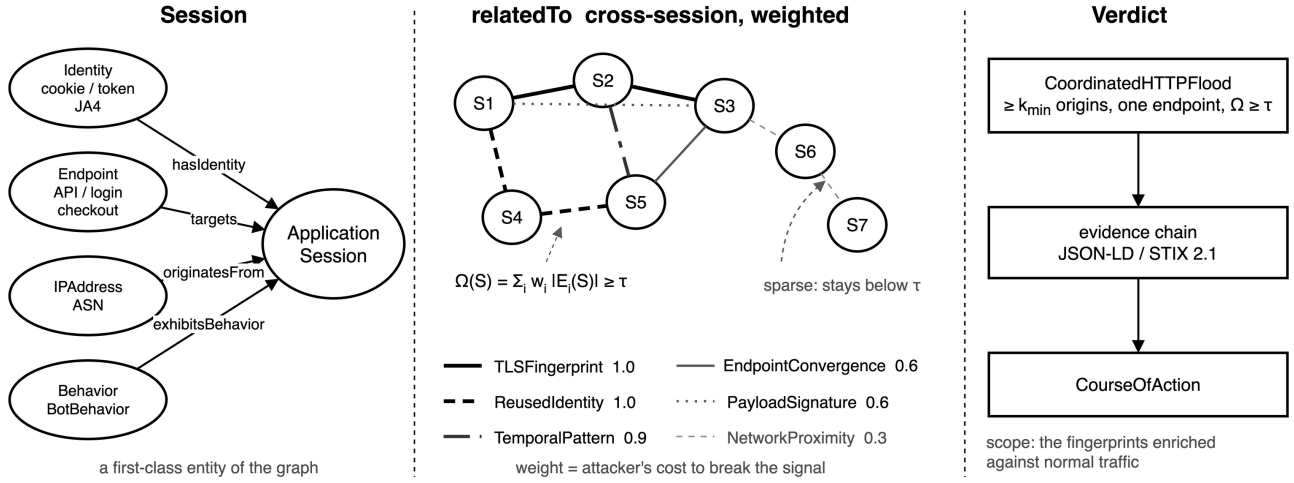


Fig. 1. Session-centric ontology and detection rule. Endpoint convergence links every pair of sessions on the endpoint; a few are drawn.

rules, and turned into a verdict that carries its evidence chain and derived mitigation scope.

A. Employing Knowledge Graphs

A knowledge graph states facts as RDF triples (subject, predicate, object), and an OWL 2 ontology declares the classes and properties they may use. We work in the OWL 2 RL profile [18], whose polynomial forward-chaining entailment makes bounded materialization tractable for runtime reasoning where OWL 2 DL is not, and materialization runs once per window, off the per-request path. SWRL adds Horn rules, which assert a triple when a conjunction of premises holds, and SPARQL queries and aggregates the result. Client identity comes from JA4 [19], a hash of the TLS *ClientHello* that identifies a client's TLS stack. Being independent of the source address, it survives IP rotation.

B. Defining the Ontology

The central class is *ApplicationSession*, related by *hasIdentity* to a composite *Identity* (cookie, JWT token, username, TLS fingerprint), by *originatesFrom* to its source *IPAddress*, by *targets* to an *Endpoint* (*AuthEndpoint*, *APIEndpoint*, *StaticAsset*), by *exhibitsBehavior* to a behavioral profile, and by *mitigatedBy* to a policy (*RateLimit*, *Challenge*, *Block*) carrying a scope attribute. The abstract class *ApplicationLayerAttack* specializes into *SlowHTTPDoSFamily*, itself split into *ConnectionExhaustionAttack* (*Slowloris*, *slow body*, *slow read*) and *CoordinatedHTTPFlood* (*HULK*, *GoldenEye*). The ontology is aligned with STIX 2.1 [20] and MITRE ATT&CK, and also declares *CredentialStuffing* and *CoordinatedAPIAbuse*, which reuse the same machinery but are outside the experimental scope of this paper.

C. Threat Model

The defender operates the attacked application and observes, per request, the TLS *ClientHello* (hence a JA4 fingerprint), source address and prefix/ASN, target endpoint, arrival time,

and whatever identity material the application exposes. It sees neither the botnet's control channel nor which sources are coordinated, but can profile the service's own traffic outside attack episodes. The attacker controls K compromised devices and may shape each session to be statistically indistinguishable from a legitimate one, the stealth assumption of our evaluation. The damage is exhausted capacity: each session holds a connection and a worker as a legitimate one does, so no per-session rate rises, and the aggregate grows only by the campaign's share of the endpoint's traffic. Timing, identities and payloads can be jittered, rotated or randomized, each at an operational cost that the weighting of Section III-D encodes. The TLS stack is harder to change, because it is fixed by the library each device ships, as in the router, camera and DVR botnets of the Mirai lineage [21]. Presenting a browser's *ClientHello* would require shipping an impersonation library to every device and keeping it in step with browser releases. Bots that do so, such as headless-browser farms, fall outside this model, and Sections V-D and VI evaluate them as its boundary.

D. The Weighted *relatedTo* Family

Cross-session relatedness is a structured family of relations, declared via `rdfs:subPropertyOf` under a symmetric *relatedTo* and annotated with a coordinationWeight $w_i \in [0, 1]$, depicted in Fig. 1. Each is instantiated independently from its own observed evidence, so two sessions may be linked by one, several or all six.

The ordering is an evasion-cost argument for that attacker. Changing the TLS stack means replacing the library on every device, and JA4 sorts extensions before hashing, so it stays stable under the extension randomization Chrome introduced in 2023, which breaks classic JA3 [19]. Identity reuse is equally expensive to break, because spreading a campaign over many credentials undermines its economics. Temporal coherence originates in how the botnet is operated, and random jitter can partially break it. Payload and endpoint signals are intermediate: randomizing them is cheap, but doing so costs

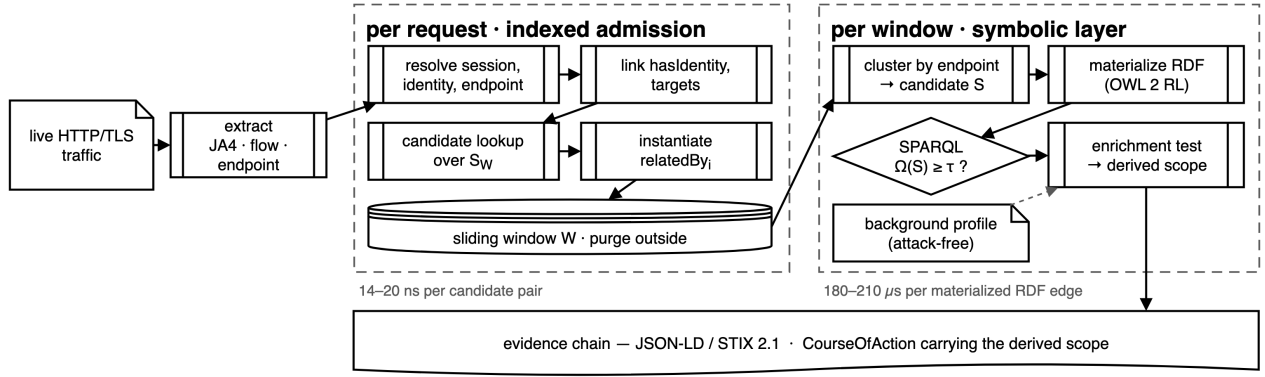


Fig. 2. Runtime pipeline, per request and per window.

campaign coherence. Network proximity is the weakest link by construction: Mirai derivatives, cloud fleets and residential-proxy networks spread across ASNs and prefixes, and carrier-grade NAT makes a shared /24 a poor discriminator. The calibration in Appendix B corroborates the ordering, and makes no claim about the absolute values.

E. Runtime Graph Construction

Sessions and relations live inside a sliding operational window ($W = 5$ min by default) and are purged incrementally, following an RDF stream-processing discipline, with materialization over Apache Jena Fuseki and TDB2 storage. Fig. 2 lays out the two layers and the rates they run at, and Appendix A gives the construction algorithm and the per-pair procedure of each `relatedBy` sub-relation. Exact JA4, endpoint and prefix matches are equivalence relations, so each partitions S into classes and $|E_i(S)| = \sum_k \binom{n_k}{2}$ over their sizes n_k in origins. Admitting a session then adds its origin to one class per such sub-relation, a hash-set insertion independent of $|S_W|$, and $\Omega(S)$ needs no pair edge. Only the non-transitive relations (near-variant JA4, temporal, payload) compare candidate pairs, which prefix indexes and locality-sensitive hashing restrict. Section V-E measures both paths against window occupancy.

F. Detection Rule

Let V_{sess} be the sessions active in W . For a subset $S \subseteq V_{\text{sess}}$ and a candidate endpoint e , define the *coordination mass*

$$\Omega(S) = \sum_{i \in \mathcal{R}_{\text{rel}}} w_i |E_i(S)|, \quad (1)$$

with $E_i(S)$ the set of pairs of distinct origins $\{o(s_a), o(s_b)\}$, $s_a, s_b \in S$, whose sessions are linked by sub-relation i , where $o(s)$ is the source address of s . Each pair counts once, so one client's many sessions cannot pose as coordination. The rule `CoordinatedHTTPFlood` holds when there exists S with (i) at least k_{min} origins; (ii) $\forall s \in S : (s, \text{targets}, e) \in E$; and (iii) $\Omega(S) \geq \tau_{\text{cluster}}$. It mitigates only when the enrichment test of Section III-H names a fingerprint; per window, S is every session to e (Appendix E).

At window scale most of this mass is volume: under condition (ii) the endpoint term is $0.6 \binom{n}{2}$ for n origins and carries 91% of Ω in the campaign of Listing 2, and with uniform weights the per-window rule detects as well as with these. A threshold on the distinct origins of the window, calibrated as τ_{cluster} is, gates at least as well, and one on the aggregate rate adds nothing, since each session keeps a legitimate rate (Appendix E). The trigger thus flags a window busier than normal traffic, and the enrichment test of Section III-H supplies the discriminator. The weights order the evidence chain and keep network proximity auxiliary: a set held together *only* by it needs three times as many linked pairs to reach a given Ω as a TLS-linked set.

G. Symbolic Formulation

Reasoning is symbolic in two stages (Listing 1). SWRL states each `relatedBy` sub-relation as a Horn rule over the predicates the evidence extractors produce; numeric ones such as DTW distance and payload cosine similarity enter as a built-in comparison against their threshold. At runtime the equality-based rules are evaluated from class sizes, with no pair edge materialized, and the aggregation, which SWRL cannot express since it cannot sum, is a SPARQL query that reads the weights from the `coordinationWeight` annotations of the ontology.

H. Evidence Chain and Derived Mitigation Scope

When the rule fires, the engine emits the satisfied rule, the instances involved, the decomposition of $\Omega(S)$ per sub-relation, and the derived mitigation scope. We export it as JSON-LD and as STIX 2.1, an *indicator* plus a *course-of-action* linked by *mitigates*, for SIEM and SOAR ingestion.

How the scope is chosen decides whether the verdict is useful or harmful, and the frequency-based choice fails. The modal fingerprint of the cluster selects whatever is common, and on a service under attack what is common is the legitimate population. Against a botnet spread over several TLS stacks, each attacker stack is smaller than the head of the benign distribution, so the modal value is a *legitimate* fingerprint and the resulting filter blocks users and no attackers (Section V-D).

We therefore select the discriminator by **enrichment**. Let $c(f)$ be the number of origins of the fired cluster that present fingerprint f , $n = \sum_f c(f)$, and $b(f)$ the prevalence of f , plus $1/N$, among the N origin–fingerprint pairs of a profile of normal traffic kept by the operator outside attack episodes. The scope admits every f that is enriched, $c(f)/n \geq \rho b(f)$, and improbable under the background, $\Pr[X \geq c(f)] < \lambda_e/|F|$ for $X \sim \text{Bin}(n, b(f))$, where the Bonferroni divisor $|F|$ counts the fingerprints of profile and cluster. The result, a *set* of fingerprints, covers a fragmented botnet. Fleets of legitimate clients that switch on together break the binomial’s independence on production traffic (Appendix E), so the level λ_e is calibrated per endpoint e as τ_{cluster} is: the largest value up to 0.01 at which the scope names a filter in at most 1% of attack-free windows. We use $\rho = 3$; on generated traffic, where each session has its own origin, λ_e stays at 0.01.

The background must come from outside the attack episode, because the campaign spans the whole window and would otherwise give every candidate an enrichment of one. No labels are involved: the profile is what a defender sees in normal operation. An adversary hiding inside a popular benign fingerprint is therefore not enriched, so the framework refuses the scope and reports that no discriminator exists.

IV. EVALUATION METHODOLOGY

This section details the evaluation methodology. Each traffic source answers one question. A generator calibrated on benign CICIDS2017 sessions and on JA4 measured at a production CDN carries the controlled campaigns of the main evaluation, laboratory captures test conventional attacks and the closest published system, and eight days of that CDN’s traffic test the rule’s false alarms and, with a botnet injected, its detection. We then present the baselines, the ablation configurations and the metrics.

A. Scenarios and Datasets

The central hypothesis has two parts: cross-session representation gains over per-session detection as the *degree of distribution* K of the campaign grows, and the symbolic path turns that structure into an auditable, low-collateral decision, so the evaluation is parameterized by K . **Scenario A** ($K = 1$), the classic single-source flood, is handled by volumetric detectors and degenerate for the per-session area under the ROC curve (AUC). **Scenario B** ($10 \leq K \leq 100$) models small botnets whose origins each stay inside their own rate limit, so network proximity is partial and high-weight signals must carry detection. **Scenario C** ($K \geq 1000$) spreads the campaign over hundreds of ASNs and prefixes, leaving negligible per-session signal and a nearly empty `relatedByNetworkProximity`; this is where the contribution must hold. We report B ($K = 50$) and C ($K = 1000$).

Primary evaluation: calibrated synthetic traffic. A generator produces distributed Slow HTTP DoS campaigns, the family of Section III-B: sustained low-rate sessions against one endpoint, with known coordination ground truth, parame-

terized by K , by the fraction of origins sharing TLS signature and identity, by IP/ASN dispersion and by the time window.

Two parameters of that generator decide whether the scenario resembles production: benign fingerprint popularity, which we measure, and botnet composition, which no published measurement fixes and we therefore sweep. The first is shaped as a Zipf curve of exponent α : real populations are concentrated, since an up-to-date browser on a given platform emits essentially one JA4 [19]. We calibrated that curve against 6.33M TLS requests logged at a production edge point of presence of Azion Technologies¹: 495 distinct fingerprints, the most common accounting for 38.4% of requests and the top ten for 93.8%. The measured curve is bracketed by $\alpha = 1.5$ and $\alpha = 2.0$. We take $\alpha = 1.5$ as canonical and sweep the range. As for botnet composition, real botnets span device classes such as routers, IP cameras and DVRs [21], and therefore TLS stacks, so we distribute 90% of the campaign uniformly over M stacks, the conservative choice for a given M , and the rest over one-off fingerprints, and take $M = 25$ as canonical. An *adversarial* mode lets the botnet adopt the most common benign fingerprints, as an impersonating bot would, and marks the boundary of the threat model. Appendix B reports the measurement and its caveats.

Legitimate distributions are calibrated against the $\sim 322k$ benign sessions of CICIDS2017 and verified by Kolmogorov–Smirnov tests: $D = 0.003$ for duration and $D = 0.002$ for request count, both with $p > 0.8$, so the benign sessions are no easier than those of CICIDS2017. A *stealth* mode draws attacker sessions from the same distributions as benign traffic, so the campaign reveals itself only through cross-session structure.

Laboratory captures. CICIDS2017 [22] (Wednesday capture: Slowloris, Slowhttptest, HULK, GoldenEye) and CIC-IoT2023 [23] (DDoS Slowloris and HTTP Flood), the latter being the dataset on which KLAGe reports $F_1 = 84.1\%$ for DDoS Slowloris, run through the same extraction pipeline (PCAP $\rightarrow$ JA4 + flows $\rightarrow$ sessions $\rightarrow$ graph). **Production traffic.** Eight days of Azion’s CDN traffic, as counts of distinct origins, connections and same-/24 pairs per fingerprint and five-minute window (Appendix E).

B. Baselines, Configurations and Metrics

Each ablation configuration is run with $n = 30$ distinct seeds, giving bootstrap intervals and paired tests. All configurations consume the same traffic attributes, so the ablation separates *representation* with data availability held fixed. τ_{cluster} is fixed per scenario at the 99th percentile of Ω over legitimate clusters, and λ_e so that the scope names a filter in at most 1% of them.

The per-session baseline is deliberately **strong**: a Random Forest (RF) over all eight to nine available flow attributes (request count and duration, byte and packet sums in both directions, mean and standard deviation of inter-request time).

¹Measured 22 August 2026 from an access log the platform already collects. The extract holds only client-software fingerprints and their frequencies, with no address, host, URI, header or locale.

TABLE II
PER-SESSION ROC AUC, REALISTIC SYNTHETIC SCENARIO.

Configuration	$K = 50$	$K = 1000$
(a) per-session ML (strong)	0.498 [.47–.53]	0.503 [.50–.51]
(b) ontology, no <code>relatedBy</code>	0.500 [.47–.53]	0.502 [.49–.51]
(c) <code>NetworkProximity</code> only	0.499 [.46–.53]	0.659 [.65–.67]
(d) cross-session repr.	0.927 [.92–.93]	0.982 [.98–.98]
<i>(a) and (d) across classifier families (point estimates)</i>		
hist. gradient boosting	0.502 / 0.921	0.501 / 0.990
multilayer perceptron	0.471 / 0.235 [†]	0.500 / 0.803
logistic regression	0.488 / 0.873	0.495 / 0.799
PCA over flow statistics [10]	0.518	0.509
PCA and k -means over a session matrix [9]	0.499	0.495
Supervised over session features [5]	0.499	0.503

$\alpha = 1.5$, $M = 25$, $n = 30$ seeds, 95% CI, legitimate users on the attacked service. The symbolic path is in Table III. [†] Below chance, see text.

To keep the negative result from depending on one hypothesis class, we repeat it with histogram gradient boosting, a multilayer perceptron and logistic regression over the same features. We also reimplement three academic baselines: PCA profiling [10], PCA followed by k -means clustering over a behavioral matrix [9], and supervised RF/SVM over session features [5]. We compare against published KLAG numbers on the same dataset and attack. The four ablation configurations are: **(a)** ML baseline without ontology; **(b)** ontology with *no* `relatedBy` sub-relation, sessions as isolated nodes; **(c)** ontology with *only* `relatedByNetworkProximity`, emulating a naive ASN/prefix detector; and **(d)** the full cross-session representation over the three sub-relations observable in the evaluated traffic. Thus (d)–(a) is the total contribution, (d)–(b) the gain of representing cross-session structure, and (d)–(c) the gain of high-weight signals over network proximity.

Configuration (d) consumes the cross-session evidence as *features*: the share of a cluster sharing one JA4 or /24, plus its size. This feature-level proxy for the `relatedBy` family keeps every configuration equal in data and classifier.

Beyond standard classification metrics we report **collateral damage**: the fraction of legitimate traffic falling inside the scope derived from the verdict. It is the false-positive rate of the filter an operator would deploy, which can differ sharply from that of the detector (Section V-D). Evidence chains are assessed for *completeness* (do they enumerate every correlated session and activated sub-relation?) and *actionability* (is the derived scope coherent with the cluster discriminator?).

V. RESULTS

The results follow the claims they support: the ablation under stealthy distributed campaigns, the rule as a detector on generated and production traffic, laboratory captures and the closest published system, what acting on the verdict costs in collateral and runtime, and significance.

A. Ablation Under Stealthy Distributed Campaigns

Table II reports the per-session AUC over stealthy distributed campaigns whose legitimate users access the *same* endpoint and port as the attack, so neither flow volume nor destination port separates the classes. Per-session detection (a)

TABLE III
THE ENRICHMENT SCOPE OF THE LARGEST- Ω CLUSTER AS A DETECTOR.

Scenario	Rule, no labels			Learned, rec. @ FPR = 0	
	Recall	FPR	F_1	(d)	+ profile
Monolithic ($M=1$)	89.8%	0.00%	0.946	91.7%	85.9%
$M=5$	90.0%	0.00%	0.948	88.6%	91.7%
$M=25$	90.3%	0.00%	0.949	36.4%	87.4%
$M=100$	38.6%	0.00%	0.556	17.6%	86.9%
$M=25$, adversarial	30.4%	3.78%	0.452	7.8%	6.6%

The learned models train on labels of the campaign they score; the second also reads the rule’s profile. $K = 1000$, $n = 15$ seeds.

with the full flow-feature set, the three academic baselines, and configuration (b), which adds per-session ontological attributes but no cross-session relation, all sit at chance ($AUC \approx 0.50$), since each attacker session is drawn from the benign distributions by construction, and (a) stays there under every classifier family (0.471–0.503), so the collapse lies in the representation. The cross-session representation (d) reaches 0.93–0.98, and (c), restricted to network proximity, only 0.50–0.66, because the botnet is dispersed.

Configuration (d) is where model choice starts to matter. Fragmenting the botnet over 25 stacks makes the cross-session evidence *non-monotonic* in the label: an attacker shares a fingerprint with a few dozen peers, a legitimate client in the benign head with hundreds. Tree ensembles carve out the intermediate band (0.98–0.99 at $K = 1000$, 0.92–0.93 at $K = 50$), logistic regression drops to 0.80 and 0.87, and the perceptron inverts at $K = 50$ ($AUC = 0.235$), having learned that a widely shared fingerprint indicates benign traffic. The rule of Section III-H needs no labeled sample to infer the benign baseline, since it reads an explicit profile of normal traffic.

That (b) sits at chance too shows per-session attributes are not enough: the *explicit relation between* sessions carries detection. The seven attack clusters of the two laboratory captures, six attacks and the DoS-Other class of CICIDS2017, come from one to seven origins in one /24, floods within reach of a per-prefix limit; Listing 2 (Appendix D) gives the evidence chain of a canonical campaign, and a human-analyst study is future work.

B. The Rule Itself as a Detector

Every number so far came from a classifier, which says nothing about the symbolic layer, so we evaluate the rule directly: the sessions matching the scope of Section III-H *are* the flagged set, with no model training and no label, and the decision arrives with its derivation. Since AUC ranks and the rule decides, we force the classifier onto the rule’s operating point (Table III).

Against a monolithic or lightly fragmented botnet the learned model is competitive at zero false positives (91.7% and 88.6% recall against 89.8% and 90.0%). At 25 stacks the rule pulls ahead, 90.3% against 36.4%, a lead it keeps over a model allowed 1% FPR (66.8%), although that model ranks well ($AUC 0.979$): its scores overlap benign traffic in the tail. That model reads no profile of normal traffic, and the rule does.

Given the profile as two per-session features, the prevalence of the session’s fingerprint and its enrichment in the cluster, the model recovers 87.4% at 25 stacks and 86.9% at one hundred, where stacks too small for a thousand-session profile to certify hold the rule at 38.6% (Section V-D). It trains on labels of the campaign it scores, which no operator holds during an attack; the rule matches it up to 25 stacks with none. In the adversarial row the rule itself incurs a 3.78% false-positive rate, and the model reaches 23.4% once allowed 1%.

Table III takes the cluster of largest Ω as fired, with no threshold. Run per five-minute window over benign arrivals we spread across an hour (Table V), $\Omega(S) \geq \tau_{\text{cluster}}$ alone fires on 78–86% of attack windows and 0.6% of clean ones, but also on 80–100% of flash crowds, and requiring the enrichment test to name a fingerprint removes every false alarm and keeps the detection, with no collateral.

Production traffic (Table VI) breaks two assumptions the generator builds in. One client opens many connections, so counted in connections the scope names a filter in 60.1% of clean windows, 26.9% in origins; and fleets of legitimate clients switch on together, so λ_e is calibrated on the preceding days, bringing the rule to 0.2% of clean windows. Its trigger acts as a volume threshold. A 99th-percentile threshold on distinct origins fires on the same windows in 86–99.6% of cases and, as the gate, halves the false alarms with no loss of detection (6 against 14 clean windows). The scope separates attack from surge. On botnet stacks that real clients also present, enrichment blocks 20.2% and 61.6% of 100 and 1 000 attackers per window, where a filter of unseen fingerprints blocks none, and it fires on 3.9% of flash crowds of 100 users, where a z -score fires on 64.5%. Joined with the unseen filter behind the origin gate, it fires on 0.1% of clean windows and blocks 38.4% and 77.7% of those botnets on new stacks, but its false alarms block a median 29.9% of the window’s clients. We chose these two refinements on the same test days, where they hold on each of the five; fresh days must confirm them (Appendix E).

C. Laboratory Captures and Comparison with KLAGe

On laboratory captures the per-session picture changes (Table IV). A *lean* per-session baseline (three attributes) collapses to $F_1 = 0.179$, but a *strong* one (eight flow attributes) reaches 0.900, because real CIC-IoT2023 Slowloris, unlike our stealthy campaigns, leaves a per-session flow signature, and the cross-session framework reaches 0.911, so coordination is not needed on this attack. The comparison with KLAGe

TABLE IV
DDoS SLOWLORIS ON CIC-IoT2023 (laboratory capture).

Method	F_1	Prec.	Rec.	AUC
KLAGe, node level [7]	0.841	-	-	-
(a) per-session ML, 3 feat.	0.179	0.691	0.103	0.551
(a') per-session ML, 8 feat.	0.900	0.901	0.899	0.987
(d) cross-session (ours)	0.911	0.908	0.915	0.982

The capture spans 143 distinct /24 prefixes; its attack clusters hold seven origins in one.

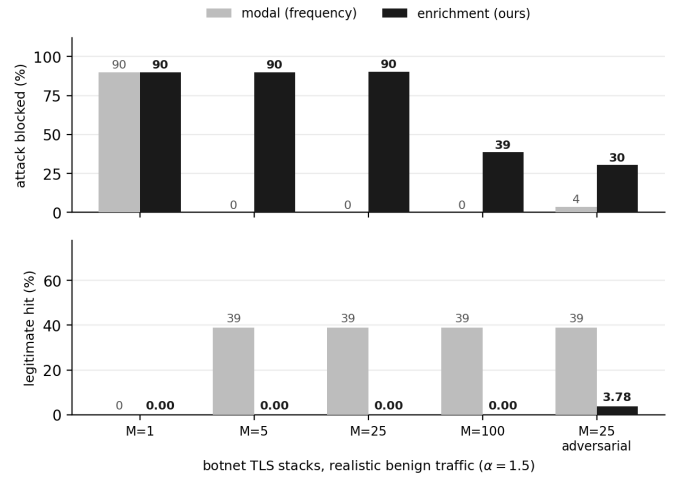


Fig. 3. Scope derivation: frequency versus enrichment ($\alpha = 1.5, n = 15$).

is favorable but *uncontrolled*: our strong baseline also beats the published 0.841, so the margin is not the representation’s, and the released code, which starts from a pre-built graph of unpublished construction and ships no weights, admits no controlled rerun. Public DDoS datasets hold only attacks with obvious flow signatures, none in the stealthy distributed regime (Fig. 4, Appendix C).

D. Collateral Damage on Legitimate Traffic

Mitigation is only meaningful as a pair, what the derived scope blocks and what it costs, which Fig. 3 reports for the frequency and enrichment rules over $n = 15$ campaigns per configuration.

For a monolithic botnet the two agree: 89.8% of attacker sessions blocked with no collateral observed, where a global endpoint rate limit disconnects every legitimate user; the frequency rule was validated in that regime, which is not representative. From five stacks on, the modal fingerprint of the cluster becomes a *legitimate* one and the rule inverts: 0.0% of the attack blocked and 39.0% of legitimate traffic hit, a net loss that imposes the cost of mitigation without its benefit. A more concentrated benign population ($\alpha = 2.0$) raises that collateral to 61.1%.

Enrichment removes the failure, blocking 90.0% and 90.3% of the attack at $M = 5$ and 25 stacks with **no collateral observed** across the $n = 15$ campaigns, and reproducing the frequency rule where it worked. The surviving 10% is the tail of attackers with one-off fingerprints, so scoped mitigation trades completeness for precision. At $M = 100$ coverage falls to 38.6%, still with no collateral: a stack of about ten sessions in two thousand cannot be told from the tail of a 1 000-session profile, and pooling 30 attack-free periods into the profile restores 89.6%.

Two conditions bound the result. The first is the boundary of the threat model: when the botnet adopts common benign fingerprints, little is enriched and the rule blocks 30.4% of the attack at 3.78% collateral, against 3.6% and 39.0% for the frequency rule, and with a stricter ρ the scope declines to

name a fingerprint, the correct report when no discriminator exists. The second is the background profile. Moderate drift is tolerable ($\alpha = 2.0$ profile against an $\alpha = 1.5$ episode: 90.3% coverage, no collateral), while a flat or missing profile makes every fingerprint look rare and collateral jumps to 77.6%. A fresh and ample profile is thus a deployment requirement: where it fails a freshness or drift check, scoped mitigation is suppressed and the verdict emitted as evidence only.

E. Cost and the Choice of W

Kept as classes (Appendix D), the equality-based sub-relations make admission constant at about $0.37 \mu\text{s}$ per session and the symbolic layer linear, at 26.4 s for 100 000 sessions against 52.8 s for pair edges at 1 000: $\Omega(S)$ grows with the square of the cluster, computing it no longer does. The AUC of (d) is flat over a $30\times$ range of W , so the representation tolerates any W the traffic permits; the rule itself ran at $W = 300$ s only.

F. Statistical Significance

Paired Wilcoxon tests over the $n = 30$ runs, Bonferroni-corrected over four comparisons, make (d)–(c) and (d)–(a) significant at $K = 1000$ ($p_{\text{Bonf}} = 7.5 \times 10^{-9}$, Cohen’s $d = 13.5$ and 22.4). Seeds are draws from one generator, so the tests show a difference stable across draws and predict nothing about the field.

VI. DISCUSSION AND LIMITATIONS

We discuss partitioning, then what bounds the results and what the graph adds (limitations continue in Appendix C).

Parallelism and partitioning. Condition (ii), one endpoint per S , makes the endpoint the natural shard key: partitioning by it evaluates the rule *exactly*, with no cross-shard traffic and per-shard state bounded by the window. A campaign spreading one JA4 across many endpoints then accumulates too few pairs in any shard to clear τ_{cluster} , while sharding by JA4 breaks the endpoint condition. No single key preserves all six sub-relations, and Appendix D sketches a two-tier design.

The gain is regime-specific. Per-IP thresholds handle single-source floods, and a strong per-session classifier reaches $\text{AUC} \geq 0.98$ on public-dataset attacks. Only distributed *and* stealthy campaigns need the framework, which complements volumetric defenses.

Each evaluation establishes one thing. The generator shows the mechanism under a mimicry imposed by construction, attacker sessions drawing their attributes from real benign distributions, so the non-separability of Table II is no artifact of a weakened baseline. Production traffic measures false alarms on real clients, and detection only for an injected botnet, over eight days of one operator; where its traffic matches the threat model (E1, a botnet a tenth of the typical window), the calibrated level holds enrichment to 0.6% of the attackers, and a profile that knows its fleets, tested on held-out days, 6.3%. No evaluation covers a captured stealthy campaign.

The representation and the scope depend on an observable high-weight discriminator. A robustness sweep ($n = 10$,

in the artifact) makes the dependency explicit: as the fraction of origins sharing the TLS fingerprint falls, $\text{AUC}(d)$ decreases monotonically from 1.00 to ≈ 0.74 under randomization, a residual of the finite benign JA4 pool, and endpoint convergence cannot compensate, since legitimate users converge there too. The volume trigger survives the loss of JA4, but the scope then finds no discriminator. Jittered timing and rotated identities leave the scope intact, since it rests on JA4; a bot outside the threat model that also presents a browser’s JA4 defeats it, and Encrypted Client Hello [24] could hide JA4.

What the graph adds. Configuration (d) expresses the graph’s evidence as features, and a linear model over the same three cross-session features still attains 0.799 against 0.495 for the per-session set, so the AUC gain of Table II comes from representing cross-session structure. OWL adds nothing to that number, nor to the trigger, which at window scale is volume, and a learned model that reads the rule’s profile and the campaign’s labels matches or exceeds the rule (Table III). What the graph adds is operational, and measurable. The ontology marks what each equality sub-relation equates, its weight, and the unit classes are counted in, and the query that counts the rule’s classes is compiled from it: on generated sessions the compiled SQL reproduces Ω exactly, run in the operator’s log store it returns the exported origin and /24-pair counts in all 1 152 windows of a day, so no address leaves the store, and a signal added to the ontology as four triples reaches the query with no change to any code. The verdict, its decomposition and the scope (Listing 2) export as one STIX 2.1 bundle that the OASIS validator accepts in strict mode, so a SOAR playbook receives a *course-of-action* already parameterized by the scope. The verdict is *explainable* in this sense of an inspectable derivation; whether it shortens an analyst’s decision is untested.

VII. CONCLUSION AND FUTURE WORK

We modeled the HTTP session as a first-class entity, related to other sessions by six typed sub-properties weighted by evasion cost, and fired a SPARQL/SWRL rule whose derivation serves as verdict, evidence chain and mitigation scope.

Against generated stealthy campaigns of compromised devices, per-session detection sits at chance across four classifiers while cross-session features reach ROC AUC 0.93–0.98, and on conventional laboratory attacks a strong per-session classifier suffices. Scoping by the cluster’s most common property selects a legitimate fingerprint once the botnet spans several TLS stacks, whereas a binomial enrichment test over normal traffic restores 90% coverage at 25 stacks with no observed collateral and no label, and fires on no generated flash crowd; a learned model matches or exceeds it only with the same profile and the campaign’s labels. On CDN traffic the trigger reduces to a count of distinct origins, and the calibrated test still names stacks shared with real clients while ignoring most flash crowds, though where the threat model holds it certifies few, a case a profile that knows the endpoint’s fleets lifts from 0.7% to 6.3%; richer fleet models, HTTP/2 attacks and a captured stealthy campaign come next.

ACKNOWLEDGMENT

We thank Azion Technologies (<https://www.azion.com/>) for authorizing the fingerprint measurement of Section IV and the aggregated traffic statistics of Appendix E, exported without addresses, ports or URIs.

REFERENCES

- [1] MITRE Corporation, “CVE-2023-44487: HTTP/2 rapid reset attack,” National Vulnerability Database, 2023. [Online]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2023-44487>
- [2] Google Cloud, “How it works: The novel HTTP/2 ‘Rapid Reset’ DDoS attack,” Google Cloud Blog, 2023. [Online]. Available: <https://cloud.google.com/blog/products/identity-security/how-it-works-the-novel-http2-rapid-reset-ddos-attack>
- [3] Cloudflare, “Hyper-volumetric DDoS attacks skyrocket: Cloudflare’s 2025 Q2 DDoS threat report,” Cloudflare Blog, 2025. [Online]. Available: <https://blog.cloudflare.com/ddos-threat-report-for-2025-q2/>
- [4] E. Cambiaso, G. Papaleo, G. Chiola, and M. Aiello, “Slow DoS attacks: Definition and categorisation,” *International Journal of Trust Management in Computing and Communications*, vol. 1, no. 3–4, pp. 300–319, 2013.
- [5] C. Kemp, C. Calvert, T. M. Khoshgoftaar, and J. L. Leevy, “An approach to application-layer DoS detection,” *Journal of Big Data*, vol. 10, no. 1, p. 22, 2023.
- [6] M. Odusami, S. Misra, O. Abayomi-Alli, A. Abayomi-Alli, and L. Fernández-Sanz, “A survey and meta-analysis of application-layer distributed denial-of-service attack,” *International Journal of Communication Systems*, vol. 33, no. 18, p. e4603, 2020.
- [7] L. Belcastro, C. Carlucci, C. Cosentino, P. Liò, and F. Marozzo, “Enhancing network security using knowledge graphs and large language models for explainable threat detection,” *Future Generation Computer Systems*, vol. 176, p. 108160, 2026.
- [8] J. Zhang, H. Zhang, C. Xia, and L. Sun, “Graph-BERT: Only attention is needed for learning graph representations,” *arXiv preprint arXiv:2001.05140*, 2020.
- [9] R. Bharathi and R. Sukanesh, “A PCA based framework for detection of application layer DDoS attacks,” *WSEAS Transactions on Information Science and Applications*, vol. 9, no. 12, pp. 389–398, 2012.
- [10] G. Fernandes Jr., J. J. P. C. Rodrigues, and M. L. Proença Jr., “Autonomous profile-based anomaly detection system using principal component analysis and flow analysis,” *Applied Soft Computing*, vol. 34, pp. 513–525, 2015.
- [11] L. Sadlek, M. Husák, and P. Čeleda, “Identification of device dependencies using link prediction,” in *Proc. IEEE/IFIP Network Operations and Management Symp. (NOMS)*, 2024, pp. 1–10.
- [12] X. Wang and R. Stadler, “IT intrusion detection using statistical learning and testbed measurements,” in *Proc. IEEE/IFIP Network Operations and Management Symp. (NOMS)*, 2024, pp. 1–7.
- [13] A. Martinetti, “Advancing threat intelligence: JA4 fingerprints and inter-request signals,” Cloudflare Blog, Aug. 2024. [Online]. Available: <https://blog.cloudflare.com/ja4-signals/>
- [14] Y. Jia, Y. Qi, H. Shang, R. Jiang, and A. Li, “A practical approach to constructing a knowledge graph for cybersecurity,” *Engineering*, vol. 4, no. 1, pp. 53–60, 2018.
- [15] V. Bonagiri, P. Priyadharshini, P. PanneerSelvi, S. Sahitya, R. Swamy, and P. Varalakshmi, “Practical applications of cybersecurity: A research paper on knowledge graphs for real-world security solutions,” in *Proc. 4th Asian Conf. on Innovation in Technology (ASIANCON)*, 2024.
- [16] K. Liu, F. Wang, Z. Ding, S. Liang, Z. Yu, and Y. Zhou, “Recent progress of using knowledge graph for cybersecurity,” *Electronics*, vol. 11, no. 15, p. 2287, 2022.
- [17] N. Tripathi and N. Hubballi, “Application layer denial-of-service attacks and defense mechanisms: A survey,” *ACM Computing Surveys*, vol. 54, no. 4, pp. 1–33, 2021.
- [18] W3C OWL Working Group, “OWL 2 web ontology language profiles, 2nd ed.” W3C Recommendation, 2012. [Online]. Available: <https://www.w3.org/TR/owl2-profiles/>
- [19] J. Althouse, J. Smart, R. J. Nunnally, and M. Brady, “JA4+ network fingerprinting,” FoxIO, 2023. [Online]. Available: <https://blog.foxio.io/ja4+-network-fingerprinting>
- [20] OASIS, “STIX version 2.1,” OASIS Standard, 2021. [Online]. Available: <https://docs.oasis-open.org/cti/stix/v2.1/stix-v2.1.html>
- [21] M. Antonakakis, T. April, M. Bailey, M. Bernhard, E. Bursztein, J. Cochran, Z. Durumeric, J. A. Halderman, L. Invernizzi, M. Kallitsis, D. Kumar, C. Lever, Z. Ma, J. Mason, D. Menscher, C. Seaman, N. Sullivan, K. Thomas, and Y. Zhou, “Understanding the Mirai botnet,” in *Proc. 26th USENIX Security Symposium*, 2017, pp. 1093–1110.
- [22] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward generating a new intrusion detection dataset and intrusion traffic characterization,” in *Proc. 4th Int. Conf. on Information Systems Security and Privacy (ICISSP)*, 2018, pp. 108–116.
- [23] E. C. P. Neto, S. Dadkhah, R. Ferreira, A. Zohourian, R. Lu, and A. A. Ghorbani, “CICIoT2023: A real-time dataset and benchmark for large-scale attacks in IoT environment,” *Sensors*, vol. 23, no. 13, p. 5941, 2023.
- [24] E. Rescorla, K. Oku, N. Sullivan, and C. A. Wood, “TLS encrypted client hello,” IETF Internet-Draft draft-ietf-tls-esni, 2024. [Online]. Available: <https://datatracker.ietf.org/doc/draft-ietf-tls-esni/>
- [25] M. Shafi, A. H. Lashkari, V. Rodriguez, and R. Nevo, “Toward generating a new cloud-based distributed denial of service (DDoS) dataset and cloud intrusion traffic characterization,” *Information*, vol. 15, no. 4, p. 195, 2024.

APPENDIX A

RUNTIME CONSTRUCTION AND SUB-RELATION INSTANTIATION

Algorithm 1 Runtime knowledge-graph construction

Require: request stream $\mathcal{R}$, ontology $\mathcal{O}$, window W

Ensure: knowledge graph KG persistent over W

```

1:  $KG \leftarrow \emptyset$ 
2: for each request  $r \in \mathcal{R}$  do
3:    $s, i, e \leftarrow \text{RESOLVESESSION/IDENTITY/ENDPOINT}(r)$ 
4:    $KG.\text{add}(s, i, e)$ ;  $KG.\text{link}(s, \text{hasIdentity}, i)$ 
5:    $KG.\text{link}(s, \text{targets}, e)$ 
6:   for each active  $s' \in S_W$ ,  $s' \neq s$  do
7:     for each sub-relation  $i \in \mathcal{R}_{\text{rel}}$  do
8:       if  $\text{HOLDS}_i(s, s')$  then
9:          $KG.\text{link}(s, \text{relatedBy}_i, s')$ 
10:      end if
11:    end for
12:  end for
13:   $KG.\text{purgeOutside}(W)$ 
14: end for
15: return  $KG$ 

```

Algorithm 1 constructs the graph over the sliding window. It enumerates pairs for clarity: the equality-based relations are kept as class counts (Section III-E), and for the others the following procedures decide, for each candidate pair (s_a, s_b) , whether the edge is instantiated.

TLSFingerprint. Two-stage match: exact equality of the full JA4 or, failing that, near variants (same transport/TLS-version/ALPN prefix, at most one symbol of difference in the ordered cipher or extension blocks), instantiated with a $ja4_distance = 1$ annotation. This absorbs version drift within one client library without admitting spurious matches across distinct stacks. Cost $O(1)$ per pair.

ReusedIdentity. Instantiated on any shared cookie, token or username, with JWTs compared by their sub claim and cookies and usernames normalized (trim, lower-case). Cost $O(1)$ amortized with an inverted index.

```

# SWRL (Horn): instantiate one sub-relation
ApplicationSession(?a) ^ ApplicationSession(?b) ^
differentFrom(?a,?b) ^
tlsJa4(?a,?j) ^ tlsJa4(?b,?j)
-> relatedByTLSPrint(?a,?b)

# SPARQL: weighted aggregation from class sizes,
# counted in distinct origins
SELECT ?e (SUM(?w * ?n * (?n - 1) / 2) AS ?omega)
WHERE {
  { SELECT ?e ?c (COUNT(DISTINCT ?o) AS ?n)
    WHERE { ?s kg:targets ?e ; kg:inClass ?c ;
            kg:originatesFrom ?o . }
    GROUP BY ?e ?c }
  ?c kg:ofRelation ?rel .
  ?rel rdfs:subPropertyOf kg:relatedTo ;
    kg:coordinationWeight ?w .
  ?e kg:tauCluster ?tau . }
GROUP BY ?e ?tau
HAVING (SUM(?w * ?n * (?n - 1) / 2) >= ?tau)

```

Listing 1. Verdict as derivation: one Horn rule and the SPARQL aggregation.

TemporalPattern. With $\Delta(s)$ the inter-arrival times of a session of at least three requests, the edge holds when $\text{DTW}(\Delta(s_a), \Delta(s_b)) / \max(|\Delta(s_a)|, |\Delta(s_b)|) \leq \tau_{\text{DTW}}$. Fast-DTW under a Sakoe–Chiba band makes the cost linear per pair, and locality-sensitive hashing over summary vectors avoids all-pairs comparison.

PayloadSignature. Over the mean and deviation of body size and hashes of the dominant User-Agent and Content-Type, the edge holds when cosine similarity exceeds τ_{payload} .

EndpointConvergence. Instantiated when both sessions converge on the same endpoint, under path-pattern normalization (`/api/users/12345` $\rightarrow$ `/api/users/{id}`) by default; an additional exact-path match annotates the edge with *exact* = *true*. Cost $O(1)$ with a prefix-tree index.

NetworkProximity. Instantiated on a shared IPv4 /24 (or IPv6 /48) prefix, or a shared ASN, or both; when both hold the edge is annotated *strong* = *true*. ASN resolution uses current BGP tables. Cost $O(1)$ with an inverted prefix index.

APPENDIX B WEIGHT CALIBRATION

Empirical calibration depends critically on the realism of the traffic. On laboratory datasets, with a few dozen distinct JA4 fingerprints, optimization even inverts the sign of the TLS signal, because benign sessions share fingerprints more than partially coordinated campaigns do, a testbed artifact of low JA4 diversity.

In the realistic scenario users hit the attacked service with fingerprints drawn from a pool of 2000, whose Zipf shape the 495 measured at one point of presence fix; the pool exceeds the 76–818 that each production endpoint of Appendix E shows over its calibration days, so the benign tail runs longer than observed. We calibrate by maximizing per-session attack-vs-benign ROC AUC over the score $w_{\text{tls}} z(\text{ja4}) + w_{\text{ep}} z(\text{endpoint conv.}) + w_{\text{net}} z(\text{net prox.})$ with standardized attributes, over the grid $\{0.3 \dots 1.0\}^3$ (125 combinations, 60 scenarios, 91 500 sessions). The result corroborates the proposed ordering: the best vector is ($w_{\text{tls}}=1.0$, $w_{\text{ep}}=0.3$, $w_{\text{net}}=0.3$), and the TLS fingerprint is

the only individually discriminative signal (isolated AUC = 0.93, against 0.50 for endpoint convergence and 0.58 for network proximity). The weights of Fig. 1 (1.0, 0.6, 0.3) attain the same optimal AUC = 0.943 and are insensitive to $\pm 20\%$ perturbation. Calibration therefore validates the *ordering*; in the pure same-service regime the medium and low weights are not separately identifiable, since both sit near chance. Their absolute values remain open: the per-window rule detects the same with uniform weights (Appendix E), so they order the evidence more than they drive detection.

Generator Realism

Two caveats apply to the measurement: the log carries no connection identifier, so weighting is per request, which if anything *overstates* concentration, and the sample is one point of presence over one window. The CICIDS2017 testbed [22] is more concentrated still (52.7% head). The measured head matches $\alpha = 1.5$ (38.9% against 38.4%) and its top ten $\alpha = 2.0$ (94.2% against 93.8%), so the sweep brackets it.

APPENDIX C ADDITIONAL LIMITATIONS

Session and identity instrumentation. The approach assumes sessions, identities and TLS fingerprints can be extracted from traffic events; where that instrumentation is partial or noisy, performance degrades. Counting origins by source address undercounts users behind a CGN address and overcounts clients that rotate IPv6 privacy addresses, for which the /64 is the natural unit.

Graph maintenance cost. The symbolic figures of Appendix D are an upper bound, for the reason given there, and the production run of Appendix E is offline, over aggregated counts per endpoint, so a live CDN deployment still needs the partitioning of Section VI, which we did not implement.

Protocol coverage. HTTP/2 attacks and other application protocols (DNS, gRPC) need sub-relations beyond the Slow HTTP DoS family over HTTP/1.1.

Sub-relation coverage. The evaluated $\Omega(S)$ instantiates the three sub-relations the generator and public captures expose; identity reuse, temporal pattern and payload signature are specified (Appendix A) but not exercised, so their weights are untested.

Dataset breadth. Laboratory validation covers one dataset and one attack for the head-to-head comparison, plus six attacks across CICIDS2017 and CIC-IoT2023 for the regime analysis; RT-IoT2022, CIC-DDoS2019 and a captured stealthy campaign remain future work. Newer benchmarks keep the gap: inadequate application-layer representation is named a deficiency of BCCC-cPacket-Cloud-DDoS-2024 [25], whose 17 DDoS scenarios are all TCP-based, and we found no independent capture of the stealthy Layer-7 regime.

Explanation validation. The evidence chains of the seven laboratory clusters pass automated completeness and actionability checks (7/7) when counted in sessions; counted in origins, the five of CICIDS2017 hold one to three sources, below k_{min} , and the two of CIC-IoT2023 hold seven; no user study tested them.

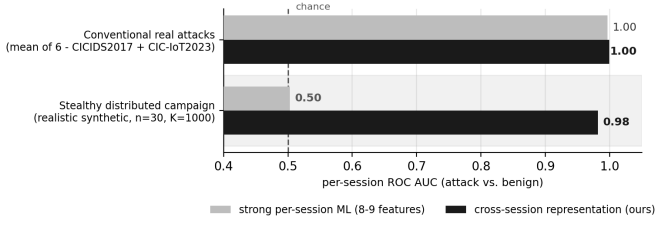


Fig. 4. Where cross-session evidence is needed.

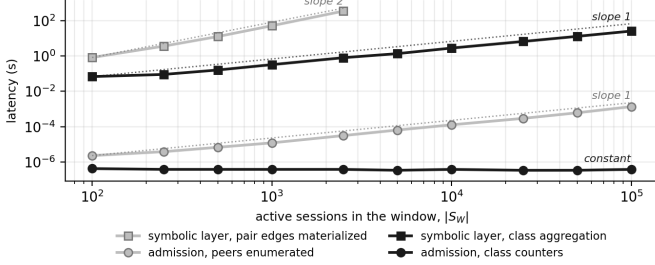


Fig. 5. Cost of both layers, with pair edges and with class counts.

APPENDIX D

COST MODEL AND WINDOW SENSITIVITY

Admission happens per request while materialization and the Ω aggregation run once per window, so we time the two layers separately, on a synthetic window in the realistic mix (30% of sessions in one campaign sharing a botnet JA4, benign JA4 from a pool of 2000, eight endpoints, dispersed /24s), with medians over three repeats on one core. Each layer runs in two ways: with pair edges, as the rules are written, and with class counts for the equality-based sub-relations. Both give the same $\Omega(S)$ for every endpoint, to within 7×10^{-12} . This is a cost model of the algorithm: the symbolic layer runs on in-memory `rdflib` in place of Jena/TDB2, so its figures are an upper bound, and counting origins adds one hash-set lookup per admission.

With pair enumeration, median admission latency grows from $2.3 \mu\text{s}$ at $|S_W| = 100$ to $127 \mu\text{s}$ at $|S_W| = 10000$, tracking the candidate-pair count (148 to 6495 edges per admission) at 15–21 ns per pair. With class counters it stays between 0.33 and $0.42 \mu\text{s}$ from 100 to 100 000 sessions (Fig. 5, where dotted lines are reference slopes).

Materializing pair edges costs 0.84 s at $|S_W| = 100$ and 52.8 s at 1000, within $198\text{--}309 \mu\text{s}$ per RDF edge, so that path is linear in edges and quadratic in sessions. Class aggregation materializes one membership triple per session and sub-relation, and computes $\Omega(S)$ with the query of Listing 1 in 0.33 s at 1000 sessions, 161 times faster, and 26.4 s at 100 000. The quadratic term thus lives in the value of $\Omega(S)$, which counts pairs, and in the pair edges of the non-transitive sub-relations, whose candidates the indexes restrict. The evidence chain needs only the pair counts (Listing 2), which the classes give.

W enters only through detection-cluster assignment, so a sweep over $W = 60\text{--}1800 \text{ s}$ recomputes the cross-session

```
"@type": "kg:CoordinatedHTTFFlood",
"kg:clusterSize": 1991, "kg:coordinationScore": 1303422.8,
"kg:activatedSubRelations": [
{"@type": "kg:relatedByTLSPFingerprint",
"kg:coordinationWeight": 1.0, "kg:linkedPairs": 114710,
"kg:weightedContribution": 114710.0},
{"@type": "kg:relatedByEndpointConvergence",
"kg:coordinationWeight": 0.6, "kg:linkedPairs": 1981045,
"kg:weightedContribution": 1188627.0},
{"@type": "kg:relatedByNetworkProximity",
"kg:coordinationWeight": 0.3, "kg:linkedPairs": 286,
"kg:weightedContribution": 85.8}],
"kg:derivedMitigationScope": {
"kg:endpoint": "10.0.0.1:443",
"kg:tlsJa4": ["t13d1516h2_synth_0001_00", ...]}
```

Listing 2. Evidence chain of a canonical campaign ($M = 25$, $K = 1000$), counted in origins; the scope lists 25 fingerprints, abridged.

TABLE V
THE RULE PER FIVE-MINUTE WINDOW, 30 RUNS PER ROW.

Windows	n_W	$\Omega \geq \tau$	Ω and enrichment		
			Fires	Cov.	Coll.
Attack, $K = 1000$	90	77.8%	77.8%	79.8%	0.0%
Attack, $K = 50$	35	85.7%	85.7%	75.3%	0.0%
Clean	360	0.6%	0.0%	–	–
Flash crowd, 25	30	80.0%	0.0%	–	–
Flash crowd, 50	30	100%	0.0%	–	–
Flash crowd, 100	30	100%	0.0%	–	–

Cov.: median share of the window's attackers the scope blocks. Coll.: largest share of its legitimate sessions blocked.

features on the same scenarios ($K = 1000$, $n = 10$): the AUC of (d) stays at $0.976\text{--}0.978$ and that of (c) at $0.663\text{--}0.664$, since the discriminative feature is the *fraction* of a cluster sharing one JA4. The scenarios target one endpoint, and W must let a cluster form (≈ 132 sessions at $W = 60 \text{ s}$).

Partitioning at CDN Scale

The design that endpoint sharding suggests, unimplemented here, is two-tiered: endpoint-sharded workers plus a global sketch over high-weight identifiers to recover campaigns that spread across endpoints. Quantifying the recall lost by the first tier and recovered by the second is a precondition for CDN-scale deployment. With class counting both layers stay linear in the window and admission well under a microsecond; confirming it at CDN scale is future work.

APPENDIX E

THE RULE PER WINDOW

Here the rule runs as deployed, per window of $W = 300 \text{ s}$ and endpoint, and no threshold sees an attack or a label. τ_{cluster} is the 99th percentile of Ω over the windows of 30 attack-free runs, which also form the profile; false alarms are counted on 30 more, detection on the canonical campaigns ($\alpha = 1.5$, $M = 25$) over windows with at least $k_{\min} = 5$ attackers, and a flash crowd retimes 25, 50 or 100 legitimate sessions of a third run into one window. We spread benign starts over 60 min, since the generator packs them into the first minutes.

A flash crowd adds mass the way a campaign does; the enrichment test tells them apart because these crowds draw

TABLE VI
THE RULE ON EIGHT DAYS OF PRODUCTION TRAFFIC.

Endpoint	Orig.	Clean (%)			Botnet blocked (%)		
		Fires	Coll.	Flash	A=100	1000	1×
E1, RUM beacons	$> 10^3$	0.1	5.4	0.1	0.0	38.3	67.6
E2, web console	$< 10^2$	0.7	50.2	5.3	0.0	83.6	0.0
E3, API	$< 10^2$	0.1	51.9	8.2	25.7	90.0	0.4
E4, SSO	$< 10^2$	0.0	–	2.2	78.8	90.0	0.9
<i>All, gated by $\Omega \geq \tau$; stacks new / shared</i>							
Enrichment		0.2	49.1	3.9	26.1/20.2	75.5/61.6	17.2/16.5
z -score		2.6	22.8	64.5	66.4/63.9	85.6/84.3	32.6/31.4
Unseen JA4		0.0	3.3	0.2	28.6/0.0	77.1/0.0	18.4/0.0
Enrich. $\cup$ unseen		0.3	48.6	4.0	37.5/20.2	77.1/61.6	18.6/16.5
<i>All, gated by distinct origins</i>							
Enrichment		0.1	31.4	3.9	26.1/20.2	76.1/62.1	18.4/17.4
Enrich. $\cup$ unseen		0.1	29.9	4.0	38.4/20.2	77.7/62.1	19.9/17.4

Orig.: origins per window. Clean: share of 5 643 attack-free windows where the scope names a filter under the gate, and the median share of their clients it then blocks. Flash: the same firing share with a flash crowd of 100 users. Botnet blocked: mean share of an injected 25-stack botnet of A attackers per window, or as large as the endpoint’s median window ($1\times$), whose stacks are absent from the traffic (new) or drawn from the profile outside its ten most common fingerprints (shared); one-off fingerprints cap it near 90%. The z -score scope is $z > 3$ against the profile; the origin gate is the 99th percentile of distinct origins, calibrated as τ .

their users from the benign mix the profile describes, while a surge on one client type is enriched, as the production fleets below show. With the test the rule fires on no clean window (95% upper bound 0.8%) and no flash crowd, and blocks a median 75–80% of the attackers in every attack window Ω flags, with no legitimate session hit. With uniform weights Ω catches the same attack windows (78.9% and 85.7%); without its endpoint term it catches 33.3% and none, and still flags 53–100% of flash crowds. A gate on distinct origins at their 99th percentile catches 82.2% and 85.7%, and with the test fires on no clean window or flash crowd either.

Production traffic. The same rule ran on eight days of access logs from the four endpoints of the operator’s own services whose windows hold at least $k_{\min}$ origins. Per fingerprint and window, the exports carry the distinct client addresses, connections and same-/24 pairs, counted inside the log store so that no address leaves it. Each of the last five days is tested with the profile, thresholds and λ_e of the days before it, clean traffic excludes clients the WAF blocked, and the canonical botnet is injected into the counts (Table VI). The exports carry no prefixes, so the scope is judged on JA4 alone.

Fleets, such as a probe fleet active only in business hours, push λ_e to about 10^{-4} (E4), 10^{-14} (E3), 10^{-60} (E1) and 10^{-73} (E2), and the scope alone then names a filter in 1.5–6.3% of the next day’s windows. When the rule fires on a clean window of E2 or E3 it names a fleet, blocking about half of that window’s clients, and up to 70% in an attack window where it names a fleet with the botnet. The origin gate halves these false alarms: the eight clean windows that only Ω admits, with the scope firing, carry 33% of their Ω outside the endpoint term, against 12% elsewhere, since a fleet concentrates on one fingerprint and lifts the TLS term where the scope misfires.

Two limits bind detection. On E1 at 1 000 attackers and on E4 at the typical window’s size the scope names botnet stacks in most windows, but Ω falls below τ_{cluster} in 57% and 94%

of them; on E2 and E3 the stacks of a botnet that size hold one or two origins, which no calibrated level certifies. At a tenth of the typical window only E1 holds more than 100 attackers, and there the calibrated level stops enrichment at 0.6%, where the unseen filter stops 11.2% and the z -score, which fires on 5.1% of E1’s clean windows, 12.5%; the union recovers the unseen filter’s share, and on shared stacks only the z -score stops any (12.2%).

A profile that knows the endpoint’s fleets narrows this limit. Fingerprints the test names at the nominal level in at least 5% of an endpoint’s calibration windows become known fleets, which leave the scope and the level’s calibration; on E1 five or six of them, 7% of the profile, set the level, which rises from about 10^{-60} to 10^{-21} . We fixed the rule for the share before running it: on the first three test days, the largest mean blocked share at no more false alarms. On the last two it lifts enrichment on E1 at a tenth of the typical window from 0.7% to 6.3% of the attackers (0.2% to 4.4% on shared stacks), at 7 false alarms against 8. Smaller shares block more but fire twice as often, on lighter filters and on more flash crowds, and an attacker presenting a known fleet’s fingerprint escapes the scope. A profile per hour of day did not help, and $\rho = 2$ or 5 moves no pooled firing rate of the table by more than 0.3 points, no blocked share by more than 4.5, and a collateral median by up to 7.2. Flash crowds of 1 000 users trigger the rule in 21.8% of windows and the z -score in 86.8%. On the full traffic of E3 and E4, 84% and 96% of the clients the scope would block were also blocked by the WAF, against 1.5% on E2, whose filters name fleets; E1 has no WAF activity.

APPENDIX F REPRODUCIBILITY

The reference implementation is available at <https://github.com/Natanaeloliveira/knowledge-graph-ddos-article> under a permissive license, organized by stage: extraction (PCAP $\rightarrow$ JA4 and flows $\rightarrow$ sessions $\rightarrow$ graph), the calibrated generator, the ablation and baselines, the symbolic layer, and the evidence and mitigation modules. The count query is compiled from the ontology and checked on generated sessions, and every exported bundle passes the OASIS STIX 2.1 validator (make compile-check stix-check). Both scope derivations ship side by side, so the negative result of Section V-D is reproducible rather than asserted. Profiles and levels come from attack-free runs, and labels enter only the evaluation: the scripts behind Table III pick the largest- Ω cluster with no label, and the per-window evaluation uses none before scoring.

Seeds are fixed and Makefiles drive every stage, so each table and data figure regenerates from one command, except the inputs of Table VI, the operator’s aggregates, whose anonymized summary ships with the artifact and is checked against the table. The source of Fig. 1 ships too, with the OWL ontology in RDF/XML and every relatedBy sub-property annotated with its coordinationWeight. We intend to submit the artifacts to the Artifact Evaluation track.